APT29 Threat Intelligence Report

Executive Summary

This report analyzes recent APT29 (Cozy Bear) campaign activity targeting government agencies and technology firms. The threat actor leverages a sophisticated multi-stage attack chain combining spearphishing, PowerShell-based payload delivery, scheduled task persistence, and credential theft techniques.

Key Findings:
- Initial access via spearphishing attachments containing malicious macros
- Heavy use of PowerShell (T1059.001) for command execution and payload delivery
- Persistence established through Scheduled Tasks (T1053.005) on compromised endpoints
- Credential dumping from LSASS memory (T1003.001) for lateral movement

Technical Analysis

Attack Chain Detail

Stage 1 - Initial Access:
The threat actor sends spearphishing emails with Word document attachments. When opened, the documents execute encoded PowerShell commands that download second-stage payloads. The PowerShell execution uses Base64-encoded commands to evade basic string detection.

Stage 2 - Execution and Persistence:
Once initial access is achieved, the malware establishes persistence by creating Windows Scheduled Tasks that execute the payload at system startup. The scheduled tasks are configured to run under SYSTEM context for elevated privileges.

Stage 3 - Credential Access:
The adversary uses Mimikatz-style tools to dump credentials from LSASS process memory. This allows lateral movement across the compromised network using stolen NTLM hashes and Kerberos tickets.

Command and Control

Stage 4 - Command and Control:
APT29 communicates with C2 infrastructure over HTTPS (Web Protocols). The malware uses legitimate cloud services as C2 channels, making detection through network monitoring more challenging. Traffic is encrypted and blends with normal web browsing.

Stage 5 - Defense Evasion:
The threat actor employs file obfuscation techniques to evade endpoint detection. Payloads are packed and encoded using custom XOR-based encoding schemes. Binary files are stored with misleading extensions and obfuscated filenames to avoid signature-based detection.

Stage 6 - Discovery:
Before lateral movement, the adversary performs extensive file and directory discovery operations to identify valuable targets and map the network structure. Standard Windows commands are used for enumeration including dir, tree, and file system traversal.